



WPScan: Técnicas de Segurança em Wordpress





O que é Wordpress?

1 CMS

Um dos Content Management Systems mais utilizado do mundo

2 Simplicidade

Fornece uma interface e extensões simples de serem utilizadas para pessoas leigas

3 No Code

Possui diversos plugins e extensões para criação de sites sem necessidade de hard-coding

Introdução ao WPScan



Ferramenta de Linha de Comando

Wordpress é executado via terminal para realizar os testes automatizados.



Opção em Docker

Possui release em docker, mas também pode ser utilizado localmente

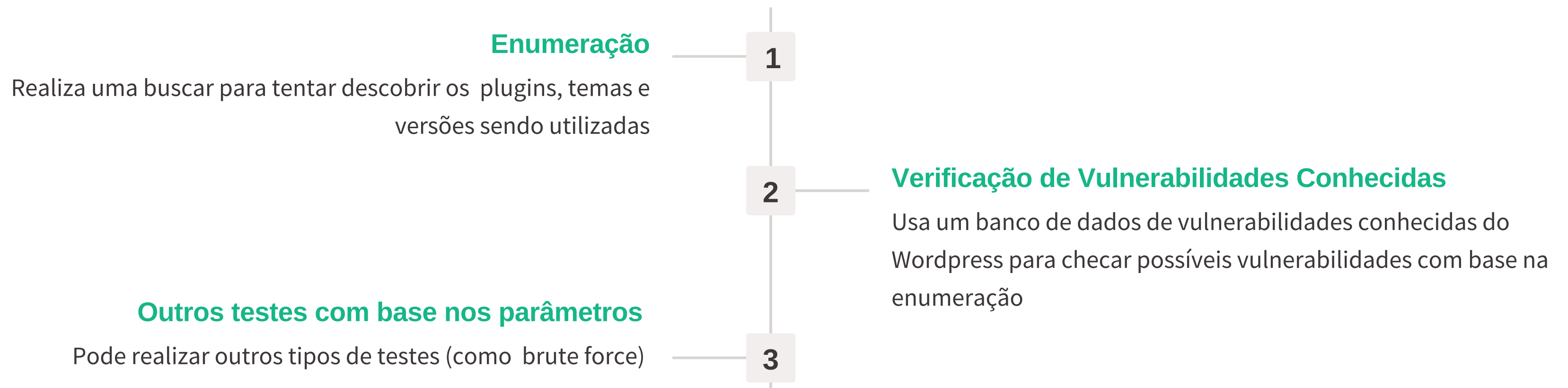


Versátil

Pode realizar diversos tipos de testes com diferentes níveis de intensidade.

Como funciona?

Como funciona?



Exemplo de comando:

```
wpscan --url https://target.com/ --enumerate u
```

Comandos Comuns

1 Varredura Inicial

Realiza testes de possíveis vetores de ataques comuns

Exemplo:

```
wpscan --url http://example.com
```

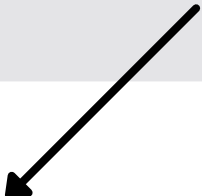
2 Enumeração de Plugins

Tenta enumerar todos os plugins utilizados pelo site. Alguns plugins contém vulnerabilidades conhecidas que podem ser exploradas a partir dessa etapa.

Exemplo:

```
wpscan --url http://example.com --enumerate p
```

Plugins



Outros tipos de enumeração

1

Enumeração de Temas

Adicione a flag `--enumerate t`

2

Enumeração de Usuários

Adicione a flag `--enumerate u`

3

Verificação de Vulnerabilidades

Este comando de detecção passiva e agressiva identifica plugins e verifica vulnerabilidades conhecidas. Ele destaca vulnerabilidades em plugins instalados ao comparar os plugins detectados com bancos de dados existentes que contêm informações sobre vulnerabilidades.

```
wpscan --url http://example.com --plugins-detection mixed
```



WPScan

Outros tipos de enumeração

Enumeração de Todas as Opções Disponíveis

Enumera todas as opções disponíveis, incluindo plugins, temas e usuários.

```
wpscan --url https://example.com --enumerate  
ap,at,au
```

Enumeração com Brute Force

Utiliza força bruta para descobrir nomes de usuário ou senhas.

```
wpscan --url https://example.com --brute  
--wordlist wordlist.txt
```

Para mais tipos de enumeração e opções:

Cheque a tabela na página do Notion

```
https://www.notion.so/rickdeszz/WPScan
```



WPScan



LET'S SCAN!!!!!!